

Cryptographie

Jean-Luc Damoiseaux

IUT-Aix-Marseille

Dpt R&T



1

2

Plan

- Généralités
- Cryptosystèmes symétriques
- Cryptosystèmes asymétriques
- Infrastructure à clefs publiques ou PKI
- Protocoles sécurisés
- Cryptographie quantique
- Cryptographie post-quantique

2

Généralités

3

4

Définitions

- La cryptographie consiste à protéger un message des personnes non habilitées à en prendre connaissance
- La cryptanalyse regroupe les techniques permettant à une personne non habilitée d'accéder à un message qui ne lui était pas destiné
- La cryptologie = cryptographie + cryptanalyse

4

5

Cryptosystème

- Ensemble d'algorithmes nécessaires à la mise en œuvre d'un objectif cryptographique
 - **Confidentialité** : l'information ne peut être lue par une personne non autorisée
 - **Intégrité** : l'information ne peut être modifiée par une personne non autorisée
 - **Authenticité** : l'information est attribuée à son auteur légitime
 - Non-répudiation : l'information ne peut faire l'objet d'un déni de la part de son auteur
- Types de cryptosystème :
 - **symétrique** (ou à **clé secrète**)
 - **asymétrique** (ou à **clé publique**)

5

6

Principe de Kerckhoff (1883) et de précaution

La sécurité d'un système de chiffrement n'est pas fondée sur le secret de la procédure mise en œuvre, mais uniquement sur un paramètre utilisé lors de celle-ci : la clef

=> Ne jamais perdre/envoyer une clef privée

=> Ne jamais utiliser un cryptosystème à vous !

6

7

Longueur des clefs

- Les algorithmes asymétriques nécessitent des clefs beaucoup plus longues que les algorithmes symétriques
- La longueur d'une clef dépend aussi de la durée de protection voulue

=> Ne jamais prendre des clefs symétriques trop longues, et des clefs asymétriques trop courtes

=> Consulter <https://www.keylength.com/fr/>

8

Entropie (force) d'un mot de passe (d'une clef)

- Un mot de passe humain est fragile car
 - Nous manquons d'imagination
 - Nous sommes fainéants
 - Les ordinateurs travaillent toujours plus rapidement

=> Ne pas oublier de consulter les sites dédiés

<https://ssi.economie.gouv.fr/motdepasse>

<https://www.security.org/how-secure-is-my-password/>

9

Entropie recommandations de l'ANSSI

Niveau de sensibilité	Longueur minimale en caractères	Taille de clé équivalente en bits
Faible à moyen	Entre 9 et 11	≈ 65
Moyen à fort	Entre 12 et 14	≈ 85
Fort à très fort	Au moins 15	≥ 100

- En contexte de sensibilité forte à très forte

- MFA
- Longueur ≥ 20 caractères

Combien de temps faut-il à un pirate pour trouver votre mot de passe 2025

12 x RTX 5090 | bcrypt (10)

Nombre de caractères	Chiffres	Lettr. majuscules et minuscules	Lettr. majuscules, minuscules et chiffres	Lettr. majuscules, minuscules, chiffres et symboles
4	Instantané	Instantané	Instantané	Instantané
5	Instantané	Instantané	57 minutes	2 heures
6	Instantané	40 minutes	2 jours	6 jours
7	Instantané	20 heures	4 mois	1 an
8	Instantané	3 semaines	15 ans	62 ans
9	2 heures	2 ans	781 ans	76 ans
10	1 jour	40 ans	48 ans	2280 ans
11	1 semaine	16 ans	234 ans	1480 ans
12	3 mois	276 ans	1018 ans	4078 ans
13	3 ans	7061 ans	4000 ans	5564 ans
14	28 ans	3880 ans	30000 ans	3000 ans
15	284 ans	477M ans	1900 ans	2180 ans
16	26 ans	10M ans	8120 ans	1580 ans
17	238 ans	322M ans	4280 ans	8400 ans
18	2306 ans	300 ans	871 ans	5270 ans

Hive Systems > hivesystems.com/password

9

10

Durée des clefs

- Il existe toujours des failles inconnues
- Il faut anticiper les avancées mathématiques et l'obsolescence des algorithmes

⇒ Ne pas oublier de régénérer les clefs

- Tous les ans pour un certificat utilisateur
- Tous les 15 ans pour un certificat de CA

10

11

Législation en France

- L'usage de la cryptographie en France est autorisé depuis 2004 sans restriction (La Confiance dans l'Economie Numérique)
- La fourniture, l'importation, le transfert intracommunautaire et l'exportation d'un moyen de cryptologie sont en revanche soumis, sauf exception, à déclaration ou à demande d'autorisation auprès de l'ANSSI par le fournisseur

11

12

Législation à l'étranger

- Différente dans chaque pays
 - des pays restreignent l'usage de la cryptographie sur leur sol (Russie, Chine,...)
 - d'autres permettent à leurs services de se livrer à des interceptions légales (même hors de leurs frontières Patriot Act pour les U.S.) sans justification...

<https://cyber.gouv.fr/publications/bonnes-pratiques-lusage-des-professionnels-en-deplacement>

12

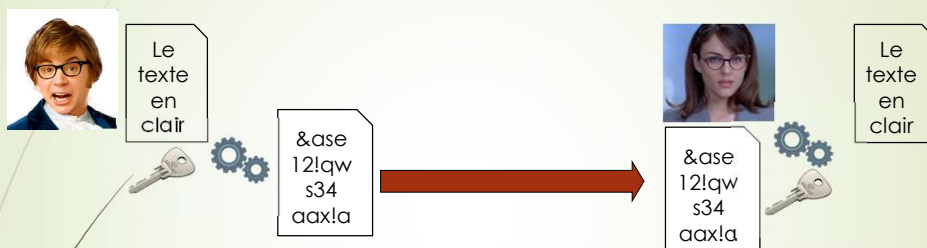
Cryptosystèmes symétriques

13

Dpt R&T JLD

14

Principe de base



- Une même clef est utilisée pour le chiffrement et le déchiffrement
- Clef de taille réduite (entre 128 et 256 bits)
- Algorithme rapide et facile à mettre en œuvre
- Fiable (si la clef est aussi longue que le texte)

14

15

Problèmes

- Nombre de clefs à créer = $n*(n-1)/2$

Nb de personnes	Nb de clef
2	1
3	3
50	1225
1000	499500

- Échange sécurisé des clefs
- Difficile d'assurer
 - l'authentification
 - la signature (authenticité + intégrité)
 - la non répudiation

15

16

Mode de fonctionnement

ANSSI : **Dangereux**, Possible, **Recommandé**

- Chiffrement par flot
 - Le message à chiffrer est de taille inconnue
 - Chaque bit/caractère est chiffré différemment au fur et à mesure
 - Algorithmes existants : **RC4**, **RC5**, **ChaCha20**
- Chiffrement par bloc
 - Le message à chiffrer est de taille connue
 - Le message est découpé en blocs de taille fixe qui sont ensuite chiffrés avec la même clef
 - **DES**, 3DES (sous certaines conditions), **AES**

16

17

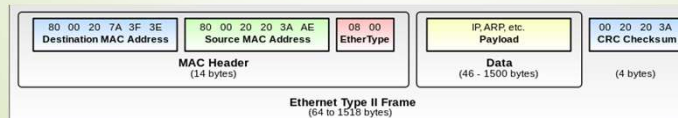
Fonction de hachage - Principe

- Algorithme basé sur une fonction mathématique qui transforme une donnée de taille arbitraire en une chaîne de bits de taille fixe (emprunte ou condensat ou haché)
- Exemples :
Clef RIB = $97 - ((89 \times \text{Etablissement} + 15 \times \text{Guichet} + 3 \times \text{Compte}) \bmod 97)$

Etablissement	Guichet	Compte	Clef RIB
14518	29267	02833165830	46

FCS calculé dans une trame par l'algorithme CRC-32 à partir du polynôme

$$x^{32} + x^{26} + x^{23} + x^{22} + x^{16} + x^{12} + x^{11} + x^{10} + x^8 + x^7 + x^5 + x^4 + x^2 + x^1$$



17

18

Fonction de hachage - Propriétés

- Deux messages distincts devraient avoir des hachés différents (résistance en collision)
- Etant donné un message, il doit être difficile de déterminer un autre message qui donnerait le même haché
- Etant donnée une valeur de haché, il doit être difficile de déterminer un message qui a donné cette valeur de haché

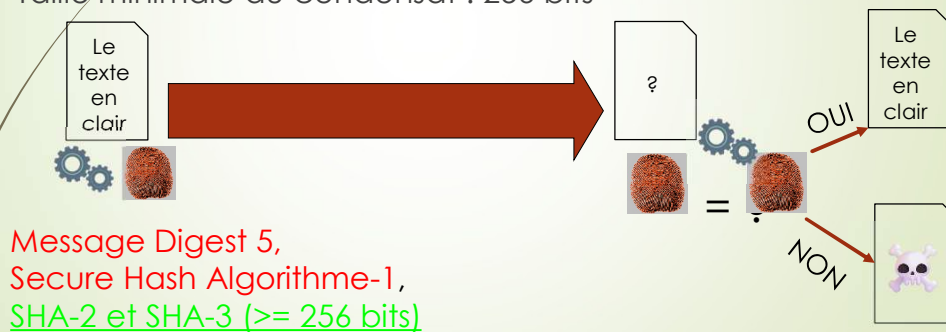
18

19

Fonction de hachage Usage courant

ANSSI : **Dangereux**, Possible, **Recommandé**

- Permet en principe de détecter l'altération (intégrité) d'un fichier
- Taille minimale du condensat : 256 bits



19

20

Fonction de hachage Autres usages

- Utilisée dans les processus :
 - D'authentification d'une personne (hmac)
 - De signature d'un "document numérique"
 - Détecter des menaces (antivirus) ou révéler la compromission de fichier sur une machine qui a été attaquée
 - Hachage de mots de passes (primitive PBKDF2 et salage)

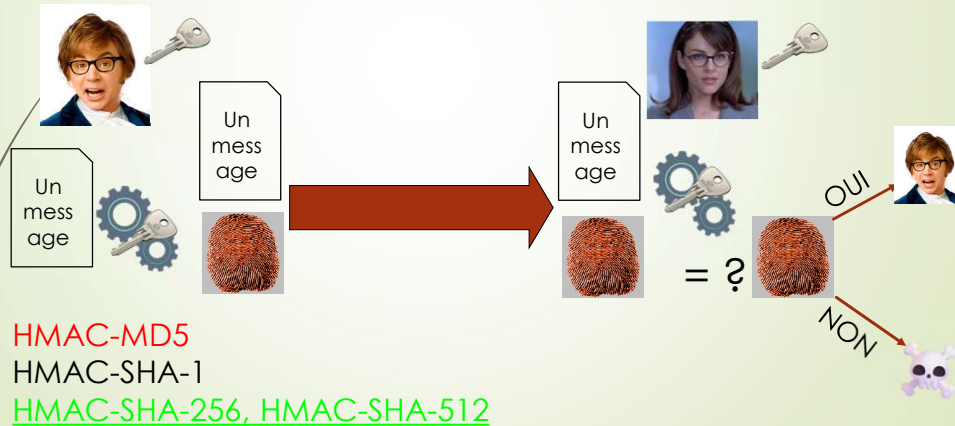
20

21

HMAC (hash based message authentication code)

ANSSI : **Dangereux**, Possible, **Recommandé**

- Utilisation d'une fonction de hachage dépendant d'une clef privée partagée pour authentifier



21

Cryptosystèmes asymétriques

22

Principe de base

- La sécurité repose sur l'existence de deux fonctions mathématiques inverses l'une de l'autre où le calcul de la première est réalisable de manière efficace, alors que celui de la seconde n'est pas réalisable en pratique si la taille des objets manipulés est importante
- Problèmes mathématiques souvent utilisés
 - Factorisation d'entiers très très très grands : comment écrire N comme un produit d'entiers premiers (RSA)
 - Logarithme discret sur un corps fini (Diffie-Hellman)
 - Logarithme discret sur courbes elliptiques (ED25519 et ECDSA pour SSH)

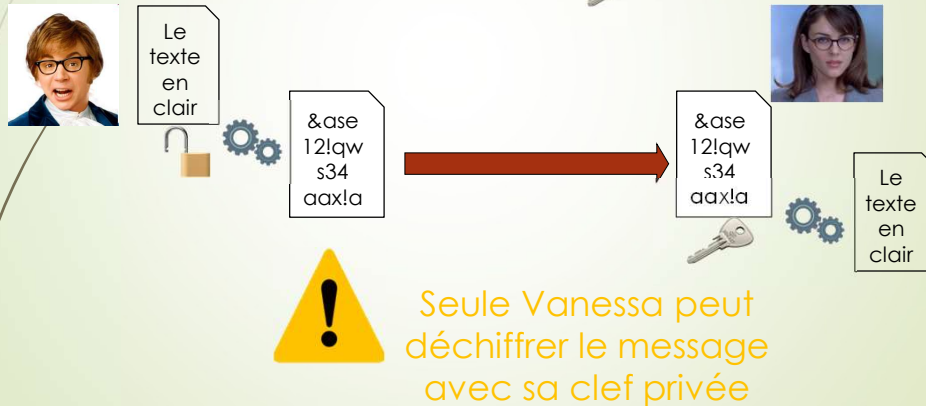
Inconvénients et avantages

- Inconvénients
 - Mise en œuvre complexe
 - Trop lent à l'exécution pour le chiffrement de données volumineuses
 - Clefs de très grande taille (1024, 2048, 4096 bits) sauf avec les courbes elliptiques (128, 256 bits)
- Avantages
 - Ne nécessite pas l'échange de clefs secrètes
 - Permet de faire facilement l'authentification, la signature, l'établissement d'une clef secrète

25 RSA - chiffrement asymétrique (dit à clefs publiques)

Vanessa possède :

- Une clef publique pour le chiffrement 
- Une clef privée pour le déchiffrement 



25

26 RSA - Calcul simplifié des clefs publique et privée de Vanessa

1. Vanessa choisit deux nombres premiers **secrets**
 $p = 3$ et $q = 11$
2. Leur produit $n = 3 \times 11 = 33$ (appelé le module de chiffrement)
3. $\phi(n) = (3 - 1) \times (11 - 1) = 2 \times 10 = 20$ (appelée l'indicatrice d'Euler)
4. Elle choisit **3** (appelé exposant de chiffrement) qui est premier avec 20 (deux nombres sont premiers entre eux si leur pgcd est égal à 1)
5. Sa clef publique est (33, 3)
6. Elle calcule l'exposant de déchiffrement qui est l'inverse multiplicatif de 3 modulo 20, et obtient **7**
7. Sa clef privée est (33, 7)

26

27

RSA – Exemple d'utilisation des clefs publique et privée de Vanessa

Austin veut transmettre le message 4 à Vanessa

- Chiffrement de 4 par Austin avec la *clef publique* de Vanessa (33, 3) : $4^3 \bmod 33 = 31$
31 est le chiffré transmis par Austin à Vanessa
- Déchiffrement de 31 par Vanessa avec sa *clef privée* (33, 7) : $31^7 \bmod 33 = 4$
Vanessa retrouve le message initial

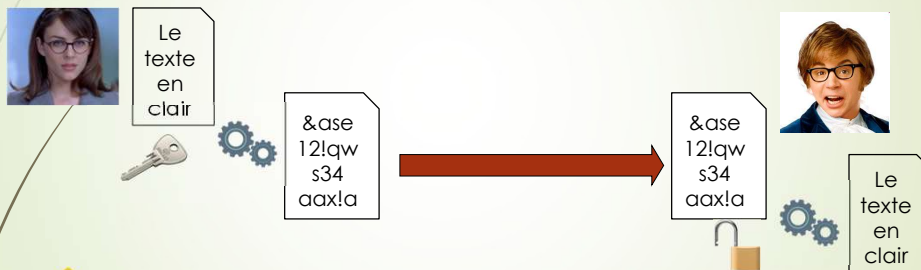
27

28

Authentification

Déchiffrement : clef publique de Vanessa

Chiffrement : clef privée de Vanessa



Si Austin peut déchiffrer le message reçu, alors il sait que c'est Vanessa (propriétaire de la clef privée) qui l'a envoyé car elle seule pouvait le chiffrer

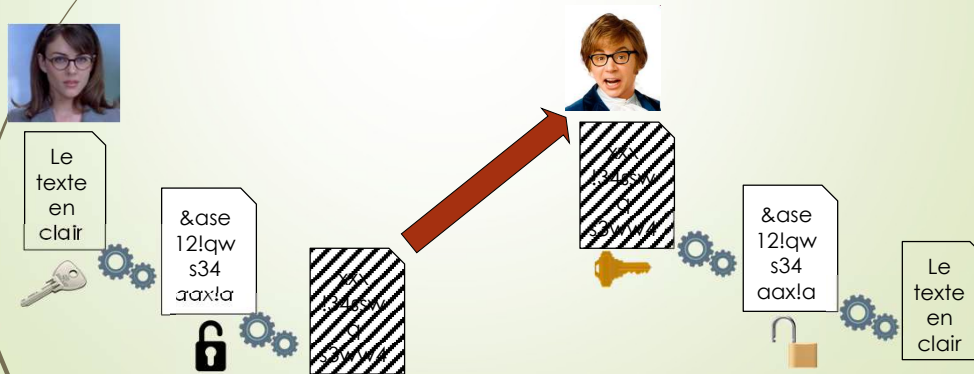
28

29

Confidentialité + Authentification

Vanessa utilise sa clef privée  pour s'authentifier
Et la clef publique  d'Austin pour chiffrer

Austin utilise sa clef privée  pour déchiffrer
Et la clef publique  de Vanessa pour vérifier l'expéditeur

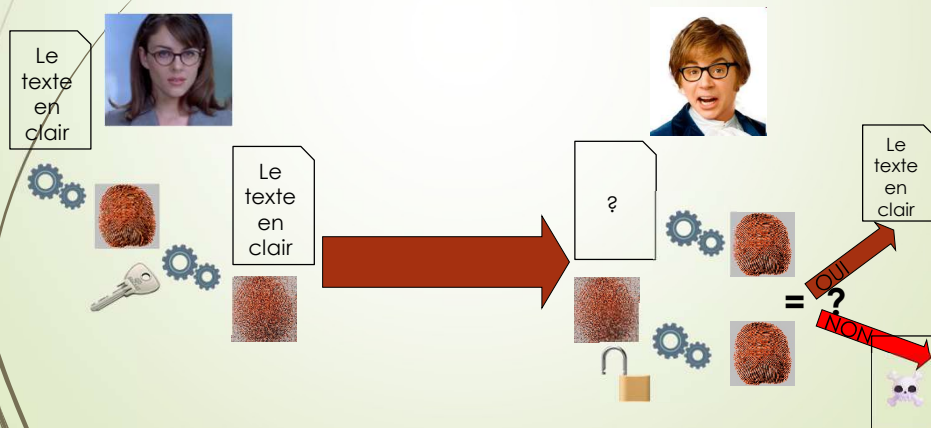


29

30

Signature (authenticité + intégrité)

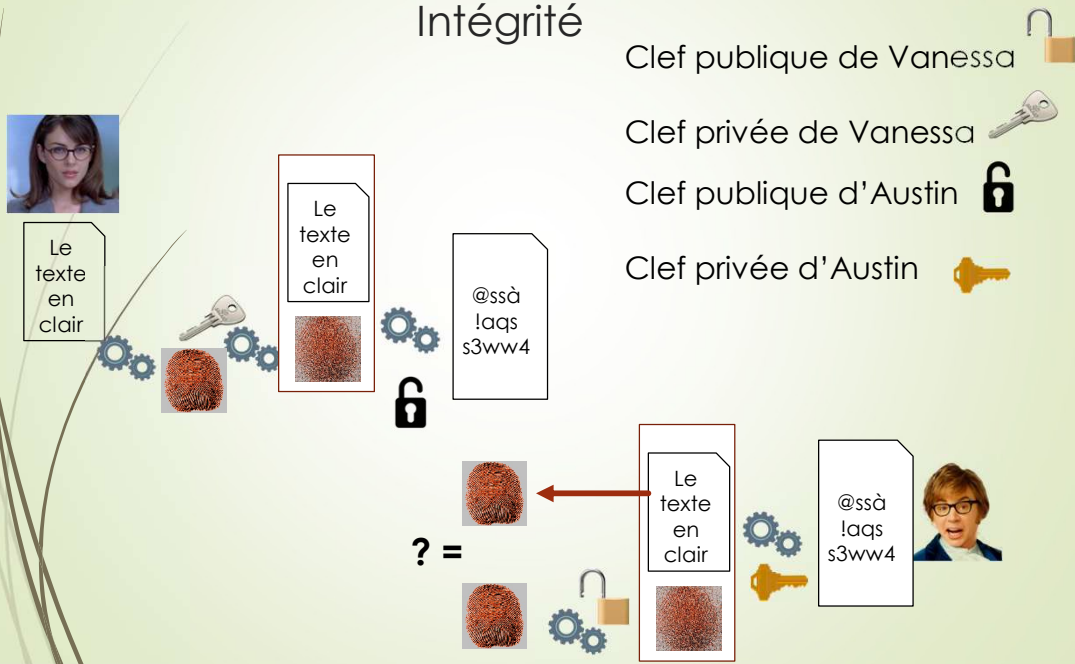
Déchiffrement : clef publique de Vanessa 
Chiffrement : clef privée de Vanessa 



30

31

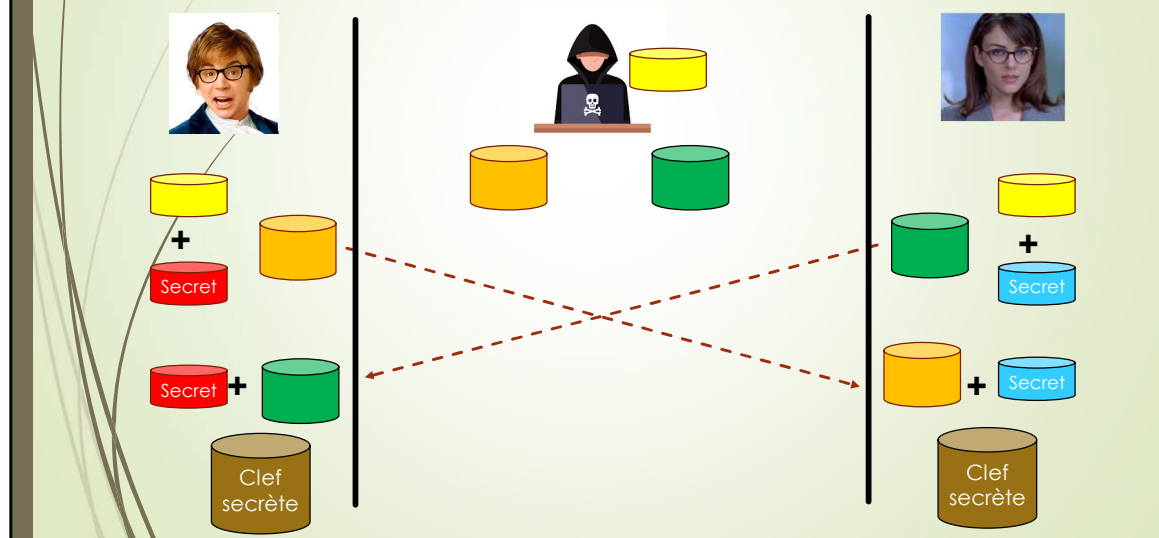
Confidentialité + Authentification + Intégrité



31

32

Etablissement d'une clef secrète – Diffie-Hellman

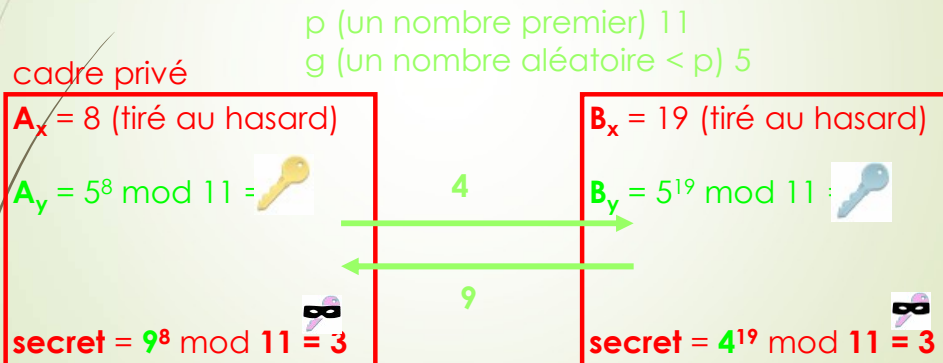


32

33

Etablissement d'une clef secrète – Diffie-Hellman en chiffre

- Etablissement d'une **clef secrète partagée** par un **échange public de valeurs**



33

Infrastructure à clefs publiques ou PKI

34

35

Problème de l'utilisation de la bonne clef publique



35

36

Certificat

- Un certificat électronique (aussi appelé certificat numérique ou certificat de clé publique) peut être vu comme une carte d'identité numérique
- Permet de s'assurer que la clef publique utilisée est la bonne car :
 - La clef publique est associée à un certificat (carte d'identité dont la structure est normalisée X509v3)
 - Ce certificat est délivré par un tiers de confiance (autorité de certification) garantissant le certificat

36

37

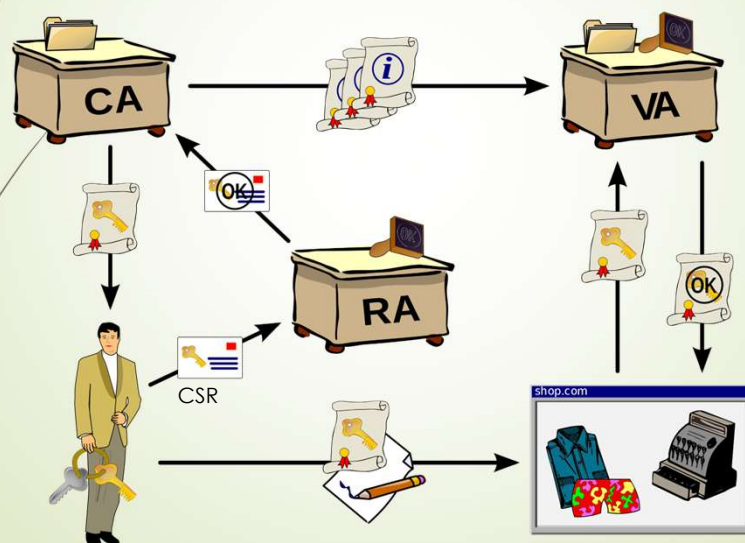
Autorité de certification

- Tiers de confiance permettant d'authentifier l'identité des correspondants
- L'autorité de certification :
 - se porte caution de l'application de la politique de certification
 - signe les demandes de certificat et les listes de révocation
 - garantit l'identité du demandeur et sa clé publique par une signature électronique
 - détermine la durée de vie du certificat et sa révocation

37

38

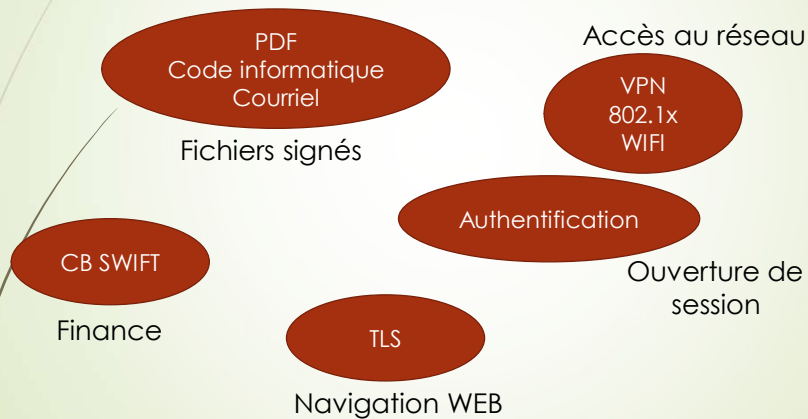
Qu'est-ce qu'une PKI (Infrastructure de gestion de clefs)



38

39

Domaines d'application des certificats



39

40

Création et signature d'un certificat X509v3

Version du certificat

Numéro de série
Algorithme de signature (RSA + SHA256)
Nom de l'autorité de certification
Période de validité (pas avant et pas après)
Nom de l'utilisateur du certificat
Information sur la clef publique de l'utilisateur
- Algorithme pour utiliser la clef publique
- Clef publique
Identifiant de l'autorité de certification
Identifiant du détenteur
Extensions (optionnel avant la v3)
SIGNATURE



40

41

Vérification d'un certificat

Version du certificat

Numéro de série
Algorithme de signature (RSA + SHA256)
Nom de l'autorité de certification
Période de validité (pas avant et pas après)
Nom de l'utilisateur du certificat
Information sur la clef publique de l'utilisateur
- Algorithme pour utiliser la clef publique
- Clef publique
Identifiant de l'autorité de certification
Identifiant du détenteur
Extensions (optionnel avant la v3)
SIGNATURE



= ?



Clef publique de l'autorité de certification

41

42

Solution au problème de l'utilisation de la bonne clef publique

Le
texte
en
clairLe
texte
en
clairCertificat
d'AustinCertificat dont la
validité peut être vérifié par Vanessa@ssà
!aqs
s3ww4Le
texte
en
clair@dxs
!ass
q4dfd

42

Protocoles sécurisés

43

44

TLS (historiquement SSL)

- Utilisé par de nombreux services réseaux (web, mail, transfert de fichier, etc.)
- Seules les versions 1.2 et 1.3 sont à utiliser
- Principes
 - L'authentification est basée sur les certificats
 - Les données sont chiffrées par une clef calculée lors de l'ouverture de la session TLS

44

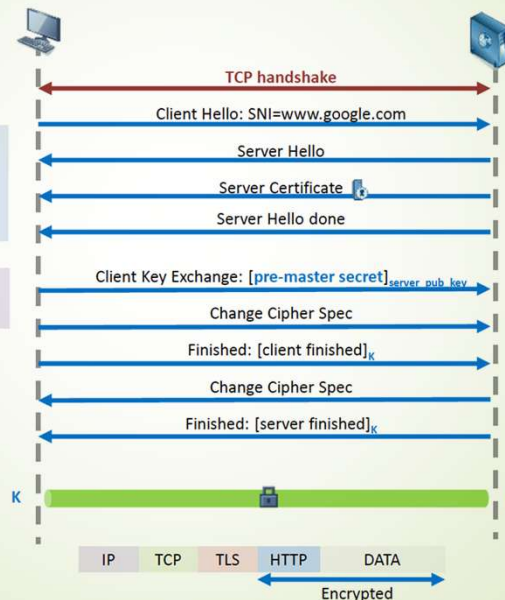
45

TLS (anciennement SSL)

Verifying the certificate presented by the server:

- SNI=cn ou AltNames
- Validity
- Signed by a trusted CA

Generate session key K using pre-master secret



Generate session key K using pre-master secret

45

46

SSH - Généralités

- SSH = Secure Shell
- Ouvre une session interactive sur une machine distante ou envoie des commandes/fichiers de manière sécurisée
 - Les données échangées entre le client et le serveur sont chiffrées
 - Le client et le serveur s'authentifie mutuellement

46

47

SSH – Fonctionnement (étape 1)

- Mise en place d'un tunnel sécurisé
 - Négociation entre le client et le serveur des politiques de sécurité à utiliser (chiffrement, hashage, échange de clefs)
 - Le serveur envoie sa clef publique au client. Celui-ci la vérifie et s'assure de l'identité du serveur
 - Le client génère une clef de session et l'envoie chiffrée au serveur
 - Le serveur déchiffre cette clef avec sa clef privée et envoie un message de confirmation chiffré avec la clef de session



A cet instant, les échanges entre le client et le serveur seront chiffrés avec la clef de session

47

48

SSH – Fonctionnement (étape 2)

- Authentification du client
 - Par mot de passe : le client envoie son nom d'utilisateur et son mot de passe qui sont alors vérifiés par le serveur
 - Par clef publique :
 - 1) le serveur crée un message, le chiffre avec la clef publique du client (préalablement déposée sur le serveur), et l'envoie.
 - 2) Le client déchiffre le message avec sa clef privée, et le renvoie au serveur.
 - 3) Si le message est le bon, l'authentification est validée

48

S/MIME (RFC 2630 à 2633)

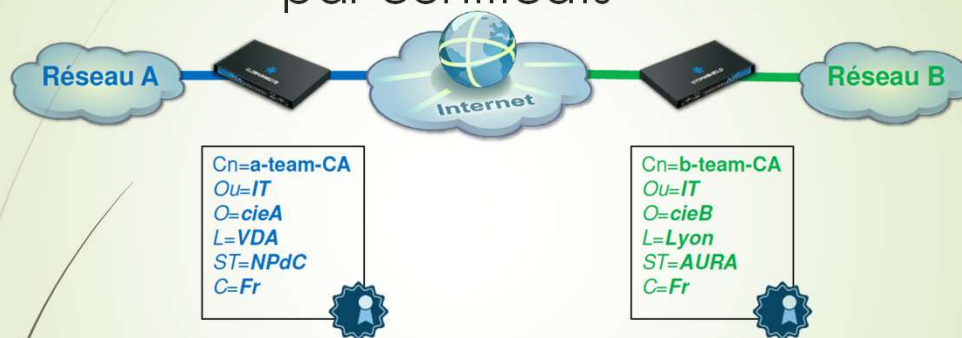
- MIME : Permet d'inclure dans les messages électroniques des fichiers attachés autres que des fichiers textes
- S/MIME (Secure / Multipurpose Internet Mail Extension)
 - Procédé de sécurisation du contenu des courriels encapsulés au format MIME
 - Assure l'intégrité, l'authentification, la non-répudiation et la confidentialité des messages électroniques.

S/MIME – Fonctionnement

- L'expéditeur envoie un mail signé avec sa clef privée mais non chiffré, et contenant son certificat
- Le destinataire vérifie le certificat avec la clef publique de la CA. Ensuite il vérifie la signature et si elle est valide alors l'expéditeur est bien celui qu'il prétend être et sa clef publique (contenue dans le certificat) est stockée par le destinataire, qui pourra si besoin l'utiliser pour envoyer un mail chiffré à l'expéditeur

51

Tunnel IPsec – Authentification par certificats



- Intérêts des certificats par rapport à une authentification par PSK
 - Révocation facile des passerelles
 - Durée de vie limitée
 - Identification unique et fiable par correspondant

51

Cryptographie quantique

52

Principes quantiques

- Superposition quantique : une particule quantique peut exister dans plusieurs états simultanément, jusqu'à ce qu'elle soit mesurée
 - Un qbit (concrètement un photon) peut être à la fois dans l'état $|0\rangle$ et $|1\rangle$
- Intrication quantique : deux particules intriquées partagent un état quantique corrélé : la mesure de l'une détermine instantanément l'état de l'autre, même à distance
- Non-clonage quantique : il est impossible de copier parfaitement un état quantique inconnu
 - ➔ un espion ne peut pas dupliquer un message quantique sans être détecté
- Mesure quantique : toute mesure d'un système quantique modifie son état
 - ➔ une écoute laisse des traces détectables car la mesure des photons introduit des erreurs

Usage et limites

- Usages
 - Distribution quantique de clés (QKD) : générations de clefs secrètes partagées
 - protocole E91 d'Artur Ekert (basé sur l'intrication)
 - protocoles BB84 de C Bennett & G Brassard (basé sur la polarisation),
 - son successeur est le protocole B92
 - Réseau quantique – état embryonnaire !
- Limites :
 - les photons s'atténuent dans les fibres optiques (limite actuelle : ~500 km avec des répéteurs quantiques)
 - Coût et complexité des infrastructures à déployer
 - Attaques par canaux auxiliaires : certaines attaques exploitent des imperfections des équipements (ex : lasers, détecteurs)

ANSSI : la QKD n'est pas une technologie assez mature et ne peut être utilisée en pratique que dans certains cas de niche

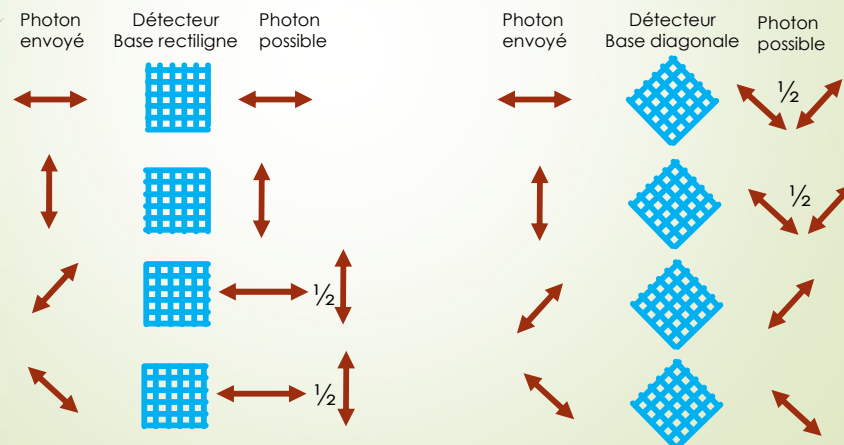
55

BB84 – Bases physiques

- Polarisation d'un photon



- Détecteur de polarisation



55

56

BB84 – Prérequis

- Accord entre l'émetteur et le destinataire sur des bases de codage

- Base rectiligne $\oplus$: 0 $\longleftrightarrow$ 1
- Base diagonale $\otimes$: 0 $\longleftrightarrow$ 1

- Techniques

- Un canal quantique unidirectionnel et sécurisé
- Un canal classique (internet, etc.) authentifié
- Générateur de nombre aléatoire



56

57

BB84 – Envoi des qbits

- Envoi d'un message aléatoire via le canal quantique



Bit à envoyer	0	0	1	0	1	1	0	1
Base choisie aléatoirement	+	+	+	×	×	+	×	×
Photon polarisé envoyé	↔	↔	↕	↗	↘	↕	↗	↘
Base choisie aléatoirement	+	×	×	×	×	+	×	+
Photon détecté	↔	↘↗	↘↗	↗	↘	↕	↗	↔↕
Valeur probable	0	0 ou 1	0 ou 1	0	1	1	0	0 ou 1

- Pour obtenir une clef de N bits, il faudra envoyer 2N bits !

57

58

BB84 – Annonce des bases

- Via le canal « public », annonce pour chaque qbit de la base utilisée
- Pour chaque qbits, si la même base a été utilisée alors on gardera la valeur probable, sinon on la jettera



Bit à envoyer	0	0	1	0	1	1	0	1
Base choisie aléatoirement	+	+	+	×	×	+	×	×
Photon polarisé envoyé	↔	↔	↕	↗	↘	↕	↗	↘
Base choisie aléatoirement	+	×	×	×	×	+	×	+
Photon détecté	↔	↘↗	↘↗	↗	↘	↕	↗	↔↕
Valeur probable	0	0 ou 1	0 ou 1	0	1	1	0	0 ou 1
Décision		On garde	On jette	On jette	On garde	On garde	On garde	On jette
Clef obtenue	0			0	1	1	0	

58

59

On nous a espionné ! ?



Bit à envoyer	0	0	0
Base choisie aléatoirement	+	+	×
Photon polarisé envoyé	↔	↔	↗
Base choisie aléatoirement par l'espion	×	×	+
Photon détecté par l'espion	↘↗	↘↗	↔↕
Photon renvoyé par l'espion	↗	↗	↔
Base choisie aléatoirement	+	+	×
Photon détecté	↔↕	↔	↘↗
Valeur mesurée	1	0	1
Décision	On garde	On garde	On garde
Valeur du bit retenu	1	0	1

59

60

BB84 – Sacrifice de bits

- Annonce via le canal « public » de la valeur de plusieurs bits (entre 20 à 50%)

Si trop de bits sont différents (taux d'erreur supérieur à 11-15%)
c'est que l'on a été écouté et toute la clef est jetée !



Bit à envoyer	0			0	1	1	0	
Base choisie aléatoirement	+			×	×	+	×	
Photon polarisé envoyé	↗			↔	↘	↕	↗	
Base choisie aléatoirement	+			×	×	+	×	
Photon détecté	↔↕			↘↗	↘	↕	↗	
Valeur mesurée	1			1	1	1	0	
Décision	On sacrifie	On jette	On jette	On sacrifie	On garde	On garde	On garde	On jette
Clef obtenue					1	1	0	

60

Cryptographie post-quantique

61

62

Problématique / Solution

- Avènement des ordinateurs quantiques !
 - compromission future et certaine des données chiffrées jusqu'à présent (Harvest Now, Decrypt Later)
 - conséquences majeures dans des domaines sensibles (étatique, militaire, finance, privé, etc.)
- Cryptographie post-quantique (PQC pour Post Quantum Cryptography) : ensemble d'algorithmes de cryptographie classique (établissements de clés, signatures numériques, etc.) assurant une sécurité contre la menace quantique

62

Actuellement

- Algorithmes certifiés (NIST / ANSSI)
 - Établissement de clés (CRYSTALS-Kyber, HQC, NTRU)
 - Signatures numériques (CRYSTALS-Dilithium, SPHINCS+)
- Solutions certifiées(ANSSI)
 - Smartcard MultiApp 5.2 Premium PQC de Thales (Thales DIS France) : Certification CC (Critères Communs) délivrée le 29 septembre 2025 ;
 - Le Microcontrôleur S3SSE2A de Samsung : Certification CC (Critères Communs) délivrée le 1er octobre 2025
- Cisco :
 - les équipements Nexus 9000 intègrent des mécanismes de sécurité résistants aux attaques quantiques
 - Nouvelle infrastructure réseau (basée sur l'intégration du protocole Secure Key Integration Protocol et la solution Solteris Network Appliance développée par ID Quantique)